

API Security Risk Analysis Report

Submitted by: Mimansha Mishra

Internship: Future Interns – Cyber Security

Task: Task 3

Repository: FUTURE_CS_03

1. Introduction

Modern applications rely heavily on APIs to exchange data between systems, mobile applications, and web platforms. While APIs improve functionality and integration, insecure APIs can expose sensitive data and allow unauthorized access.

This report presents a security analysis of a public API to identify common risks such as lack of authentication, improper authorization, and excessive data exposure. The objective is to evaluate these risks and suggest appropriate remediation measures.

2. Scope of Analysis

- API Tested: JSONPlaceholder (<https://jsonplaceholder.typicode.com>)
- Type of Testing: Read-only and ethical testing
- No exploitation or harmful actions performed
- Focus Areas:
 - Authentication
 - Authorization
 - Data Exposure

3. Tools Used

- Postman (Lightweight API Client)
- Browser DevTools
- GitHub (for documentation and submission)

4. Methodology

The analysis was conducted using the following steps:

1. Identified publicly available API endpoints
2. Sent GET requests using Postman
3. Observed API responses, headers, and status codes
4. Checked for authentication and access control
5. Analysed the type and amount of data returned
6. Documented security risks and suggested improvements

5. Findings

Finding 1 — Unauthenticated API Access

Endpoint: /users

Risk Level: Medium

Issue:

The API allows unrestricted access to user data without requiring any authentication.

Impact:

Any external user can retrieve user-related information such as names, emails, and addresses. In real-world systems, this could lead to data leakage and privacy violations.

Remediation:

Implement authentication mechanisms such as API keys, OAuth, or JWT tokens to ensure that only authorized users can access the API.

Finding 2 — Unrestricted Access to Individual User Records

Endpoint: /users/{id}

Risk Level: Medium

Issue:

The API allows access to individual user records by modifying the user ID in the request URL without any authorization checks.

Impact:

An attacker can enumerate user IDs and retrieve multiple users' data. This could expose sensitive information and lead to unauthorized access in real-world applications.

Remediation:

Implement proper authorization controls such as role-based access control (RBAC) to ensure users can only access their own data.

Finding 3 — Excessive Data Exposure

Endpoint: `/users` and `/users/{id}`

Risk Level: Low

Issue:

The API returns detailed user information including email, phone number, full address, and geographic coordinates.

Impact:

Exposing unnecessary data increases the risk of misuse. Attackers can use this information for phishing, profiling, or social engineering attacks.

Remediation:

Limit API responses to only required fields. Implement data filtering based on user roles and minimize exposure.

6. Conclusion

The analysis demonstrates that while the API is functional, it lacks important security controls such as authentication and authorization. Additionally, it exposes more data than necessary.

In real-world applications, these issues could lead to serious security risks including data breaches and unauthorized access. Implementing proper authentication, authorization, and data minimization strategies is essential to secure APIs effectively.

7. References

- OWASP API Security Top 10
- JSONPlaceholder API Documentation
- Future Interns Task Guidelines